



ARKA HEALTH, INC.

VENDOR & SUBCONTRACTOR RISK MANAGEMENT POLICY

Third-party assurance under 45 C.F.R. §§ 164.308(b), 164.314(a); SOC 2 CC9.2

ARKA-SEC-009 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-009
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE

This Policy governs the selection, contracting, monitoring, and termination of vendors, subprocessors, and subcontractors whose products or services could affect the confidentiality, integrity, or availability of ARKA Health, Inc. information or systems, and implements the business associate and subcontractor assurance requirements of the Security Rule.

2. CLASSIFICATION

Tier	Definition	Examples (current register)
Tier 1 — PHI subcontractor	Creates, receives, maintains, or transmits PHI on ARKA's behalf	Cloud infrastructure and managed database/auth providers supporting production tenants (AWS; Supabase; Vercel, when production carries PHI)
Tier 2 — Security-relevant	No PHI, but compromise could affect production or source code	Source control / CI (GitHub); identity provider; monitoring/alerting tooling
Tier 3 — General	No PHI and no production pathway	Productivity, design, and communications SaaS used without PHI

3. DUE DILIGENCE AND CONTRACTING

- Pre-engagement review.** Before engagement, Tier 1 and Tier 2 vendors are assessed by the Security Officer: current SOC 2 Type II report (or ISO/IEC 27001 certificate with statement of applicability), breach history, subprocessor lists, data-residency, and security whitepapers; findings are recorded in the vendor register.
- BAA required.** No Tier 1 vendor shall receive, or be placed in a position to receive, PHI before execution of a business associate agreement satisfying 45 C.F.R. § 164.314(a) and the flow-down requirements of ARKA-LGL-001, Exhibit A. The Company's cloud providers offer standing HIPAA BAAs (e.g., AWS, Supabase, and Vercel HIPAA offerings), which shall be executed, and the associated provider-side configuration obligations implemented, before any production deployment carrying PHI.
- Contract minimums (Tier 2).** Confidentiality, security-incident notice, and audit/attestation-sharing obligations.
- Approval.** New Tier 1 engagements require the written approval of the Security Officer and notation in the subprocessor register made available to Customers under ARKA-LGL-001, § 2.5.

4. ONGOING MONITORING

Tier 1 and Tier 2 vendors are re-assessed every twelve (12) months: refreshed attestations are collected and reviewed for relevant findings and complementary user-entity controls, which are mapped to ARKA's implementing controls; provider security bulletins and status feeds are monitored continuously. Beginning with the compliance date of the amended Security Rule, ARKA shall obtain from each Tier 1 subcontractor an annual written verification of the deployment of required technical safeguards, consistent

with the 2025 rulemaking. A vendor’s material security failure, lapsed attestation, or uncured contractual breach shall trigger a risk re-assessment and, where warranted, migration planning and termination under the applicable agreement.

5. SHARED-RESPONSIBILITY DOCUMENTATION

For each Tier 1 provider, the Security Officer shall document the division of control responsibility (provider-managed versus ARKA-managed) — including, without limitation, encryption configuration, network controls, backup configuration, and identity settings — so that no required safeguard is unowned. This mapping is an input to the annual risk analysis (ARKA-SEC-002) and the SOC 2 system description (ARKA-RDY-002).

6. OFFBOARDING

Upon termination of any Tier 1 vendor, ARKA shall obtain return or certified destruction of PHI in accordance with the applicable BAA and NIST SP 800-88, revoke all credentials and integrations within twenty-four (24) hours, and record completion in the vendor register.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company’s operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026